Criterios de Evaluación y Pruebas

1. Contraste de arquitecturas: Unsecure y Secure

La arquitectura unsecure debe evidenciar el uso de mecanismos vulnerables, como la autenticación basada en contraseñas estáticas y la falta de monitoreo estructurado ante brechas de seguridad.

La arquitectura secure debe demostrar la integración exitosa de FIDO2/WebAuthn para el login, OAuth 2.0 con PKCE y JWT en Spring Security, junto con la capa de observabilidad de OpenTelemetry.

2. Pruebas de autenticación: Mitigación de Spoofing y Phishing

El flujo de autenticación debe requerir confirmación del dispositivo biometría o enclave seguro, garantizando que la clave privada nunca abandone el hardware del usuario

El sistema debe ser algorítmicamente resistente al credential stuffing, eliminando la necesidad de almacenar o validar contraseñas compartidas en la base de datos del servidor.

3. Pruebas de observabilidad y trazabilidad: OpenTelemetry y Grafana

Las peticiones desde el cliente React hasta el servidor Spring Boot deben instrumentarse automáticamente, inyectando y propagando un TraceID único por sesión.

El OTel Collector debe exportar la telemetría unificada a Grafana vía OTLP, permitiendo visualizar la tasa de intentos de login y reconstruir el recorrido completo de cualquier sesión post-autenticación.

4. Gestión segura de sesiones Frontend y Backend

El cliente React debe generar el code verifier de OAuth 2.0 y mantener los tokens JWT exclusivamente en memoria, prohibiendo su almacenamiento en localStorage para mitigar ataques XSS.

Spring Security debe validar la firma RS256 de cada JWT entrante y aplicar control de acceso basado en roles RBAC de forma granular sobre los endpoints.

5. Validación Normativa y de Estándares

La arquitectura debe sustentar el cumplimiento del nivel AAL2 del NIST SP 800-63-4 mediante el uso de passkeys sincronizables.

Se debe evidenciar la mitigación de fallas críticas del OWASP Top 10, específicamente A07:2021 las cuales son fallas de autenticación y A09:2021 fallas en el registro y monitoreo de seguridad

6. Criterios de Aceptación de la Demo Técnica: Video de 5 min

El video debe demostrar sin interrupciones la experiencia de usuario realizando un login sin contraseña desde el frontend en React

Inmediatamente después del login, el video debe mostrar en Grafana la captura de los eventos de seguridad en tiempo real, evidenciando el dashboard de autenticación y las trazas generadas por las acciones del usuario.